IAM HOME LAB PORTFOLIO

Lab 02

RBAC Design, Role Engineering & Access Governance

Opeyemi Ogundimu • IAM Analyst | Identity & Access Management Specialist
https://github.com/okpe027/IAM-HomeLab-Portfolio

Lab Number	Lab 02 of 20
Phase	Phase 1 — Active Directory & On-Premises Identity Operations
Duration	Weeks 1–2 (continues from Lab 01)
Environment	VMware Workstation • Windows Server 2022 • Active Directory • Excel
Status	Completed ✓
Date Completed	April 9, 2026
Domain	FictionalCorp.local
Users Created	10 user accounts across 4 departments + 1 service account
Groups Created	14 security groups implementing full RBAC model
Findings	2 findings raised (Privilege Creep + SoD violation) — both remediated

1. Lab Objective

This lab implements a production-grade Role-Based Access Control model for FictionalCorp, mirroring the full RBAC engineering cycle that IAM analysts and administrators perform in enterprise environments. The lab covers the complete workflow: discovery and requirements gathering, role inventory design, role matrix construction, SoD policy documentation, Active Directory implementation, privilege creep detection and remediation, role change processing, and quarterly access certification.

Competencies demonstrated in this lab:

- Designing a formal role inventory mapping job functions to system permissions
- Building and formatting a production-grade role matrix with risk classifications
- Documenting and enforcing a Segregation of Duties policy
- Implementing 14 security groups in Active Directory matching the role matrix
- Provisioning 11 accounts including a service account with restricted privileges

- Detecting, documenting, and remediating privilege creep and SoD violations
- Processing a formal role change ticket with clean access swap
- Conducting a quarterly access certification with a compliance summary

2. Real-World Context

WHAT IAM ANALYSTS DO DAILY

IAM analysts enforce role-based access control and least-privilege principles across systems and applications, perform regular access reviews and user entitlement certifications to meet internal policies and regulatory requirements, and collaborate with application owners to define access roles, entitlements, and approval workflows.

This lab replicates all of these responsibilities in a structured, documented format that mirrors enterprise IAM operations.

3. Discovery Phase — Business Requirements

Before any group or account was created, a formal business requirements brief was reviewed. This mirrors the real-world expectation that IAM changes are always driven by documented business need, never by assumption.

```
FROM:    James Carter, IT Director
TO:      IAM Team
RE:      FictionalCorp Access Requirements Review

FictionalCorp has 4 departments: HR, Finance, IT, Sales.
6 core systems require access controls:

  1. Active Directory (AD Login)     - All staff
  2. Microsoft 365 / Email           - All staff
  3. Finance System (FinanceCore)    - Finance only
  4. HR System (PeopleHub)           - HR only + manager read access
  5. Sales CRM (SalesPro)            - Sales only
  6. IT Admin Console (ITConsole)    - IT staff only

Special requirements:
  - No Finance user can both create AND approve invoices (SoD)
  - No IT Support staff can hold admin rights (PoLP)
  - Contractors restricted to assigned system only
  - Managers need read access to HR reports only
  - Service accounts must be documented separately

IAM Team Lead: Opeyemi Ogundimu
```

4. Role Inventory

Before building anything in Active Directory, a formal role inventory was produced mapping every distinct job function to a unique role ID. This is the foundation of all subsequent access control decisions.

Role ID	Role Name	Department	Account Type	Description
R001	HR-Manager	HR	Permanent	Full PeopleHub access + HR management functions
R002	HR-Coordinator	HR	Permanent	Standard HR operations
R003	Finance-Manager	Finance	Permanent	Full FinanceCore + invoice approve oversight
R004	Finance-Analyst	Finance	Permanent	FinanceCore + invoice create only (SoD enforced)
R005	Finance-Approver	Finance	Permanent	FinanceCore + invoice approve only (SoD enforced)
R006	IT-Manager	IT	Permanent	Full ITConsole + admin rights
R007	IT-Support	IT	Permanent	ITConsole access — no admin rights (PoLP)
R008	IT-Contractor	IT	Contractor	ITConsole read-only — time-limited account
R009	Sales-Manager	Sales	Permanent	SalesPro + read access to HR headcount reports
R010	Sales-Rep	Sales	Permanent	SalesPro standard access only
R011	Service-Account	N/A	Non-human	Application-to-application only — no interactive login

5. Role Matrix

The role matrix maps every role to its permitted access across all 6 FictionalCorp systems. This document is the single source of truth for access control decisions and the primary evidence produced during compliance audits.

Document: FictionalCorp — RBAC Role Matrix v1.0 | Owner: IAM Team — Opeyemi Ogundimu | Classification: Internal — Confidential | Review Cycle: Quarterly

Role	AD Login	Email	FinanceCore	PeopleHub	SalesPro	ITConsole	Inv.Create	Inv.Approve	Admin
HR-Manager	Allow	Allow	Deny	Allow	Deny	Deny	Deny	Deny	Deny
HR-Coordinator	Allow	Allow	Deny	Allow	Deny	Deny	Deny	Deny	Deny
Finance-Manager	Allow	Allow	Allow	Read-Only	Deny	Deny	Deny	Allow	Deny

Role	AD Login	Email	FinanceCore	PeopleHub	SalesPro	ITConsole	Inv.Create	Inv.Approve	Admin
Finance-Analyst	Allow	Allow	Allow	Deny	Deny	Deny	Allow	Deny	Deny
Finance-Approver	Allow	Allow	Allow	Deny	Deny	Deny	Deny	Allow	Deny
IT-Manager	Allow	Allow	Deny	Deny	Deny	Allow	Deny	Deny	Allow
IT-Support	Allow	Allow	Deny	Deny	Deny	Allow	Deny	Deny	Deny
IT-Contractor	Allow	Deny	Deny	Deny	Deny	Read-Only	Deny	Deny	Deny
Sales-Manager	Allow	Allow	Deny	Read-Only	Allow	Deny	Deny	Deny	Deny
Sales-Rep	Allow	Allow	Deny	Deny	Allow	Deny	Deny	Deny	Deny
Service-Account	Deny	Deny	Allow	Deny	Deny	Deny	Deny	Deny	Deny

> Risk Classification: FinanceCore, PeopleHub, and ITConsole are rated HIGH risk systems. SalesPro and Email are rated MEDIUM. AD Login is STANDARD. Higher risk systems receive stricter access controls and more frequent review cycles.

6. Segregation of Duties Policy

A formal SoD policy was documented prior to implementation, defining all conflicting role pairs that are prohibited in FictionalCorp. This policy governs every provisioning decision involving Finance and IT roles.

Conflict ID	Role A	Role B	Risk	Rating	Regulatory Reference
SOD-001	Finance-Analyst (Invoice Create)	Finance-Approver (Invoice Approve)	Single user can create and approve own invoices — enables financial fraud	CRITICAL	SOX — Section 404
SOD-002	IT-Support	IT-Manager (Admin Rights)	IT Support must not hold admin privileges — privilege escalation risk	HIGH	ISO 27001 — A.9.2.3
SOD-003	Any human role	Service-Account	Service accounts must not be shared with or	HIGH	NIST SP 800-53 — AC-6

Conflict ID	Role A	Role B	Risk	Rating	Regulatory Reference
			assigned to human users		

Exception Process: Any SoD exception requires written approval from the CISO, must be documented in the SoD Exception Register, and reviewed quarterly. Undocumented exceptions are treated as audit findings.

7. Active Directory Implementation

7.1 Security Groups Created

14 security groups were created across 4 departmental OUs and 1 dedicated Service Accounts OU, matching the role matrix exactly. Permissions are assigned to groups, never to individual user accounts.

Group Name	OU	Scope	Maps to Role	Purpose
GRP-HR-Managers	HR	Global	R001	HR Manager full access
GRP-HR-Coordinators	HR	Global	R002	HR Coordinator standard access
GRP-Finance-Managers	Finance	Global	R003	Finance Manager oversight
GRP-Finance-Analysts	Finance	Global	R004	Finance Analyst operations
GRP-Finance-Approvers	Finance	Global	R005	Finance Approver operations
GRP-Finance-InvoiceCreate	Finance	Global	R004	Invoice creation permission
GRP-Finance-InvoiceApprove	Finance	Global	R003/R005	Invoice approval permission
GRP-IT-Managers	IT	Global	R006	IT Manager full access
GRP-IT-Support	IT	Global	R007	IT Support limited access
GRP-IT-Contractors	IT	Global	R008	IT Contractor read-only
GRP-IT-Admins	IT	Global	R006	Admin rights — IT Manager only
GRP-Sales-Managers	Sales	Global	R009	Sales Manager access
GRP-Sales-Reps	Sales	Global	R010	Sales Rep standard access
GRP-ServiceAccounts	Service_Accounts	Global	R011	All service accounts

7.2 User Accounts Provisioned

11 accounts were provisioned following a ticket-based workflow. Every account was logged in the FictionalCorp Provisioning Log before creation.

Username	Full Name	Department	OU	Groups Assigned	Account Type
l.okafor	Linda Okafor	HR	HR	GRP-HR-Managers	Permanent
p.sharma	Priya Sharma	HR	HR	GRP-HR-Coordinators	Permanent
a.chen	Alex Chen	Finance	Finance	GRP-Finance-Analysts, GRP-Finance-InvoiceCreate	Permanent
r.thompson	Rachel Thompson	Finance	Finance	GRP-Finance-Approvers, GRP-Finance-InvoiceApprove	Permanent
m.obi	Michael Obi	Finance	Finance	GRP-Finance-Managers, GRP-Finance-InvoiceApprove	Permanent
d.osei	David Osei	IT	IT	GRP-IT-Support (updated to IT-Manager — see CHG-0001)	Permanent
k.nwosu	Karen Nwosu	IT	IT	GRP-IT-Managers, GRP-IT-Admins	Permanent
m.williams	Marcus Williams	Sales	Sales	GRP-Sales-Reps (provisioned Lab 01)	Permanent
j.adeyemi	James Adeyemi	Sales	Sales	GRP-Sales-Managers	Permanent
f.alhassan	Fatima Al-Hassan	Sales	Sales	GRP-Sales-Reps	Permanent
svc.financecore	FinanceCore App	N/A	Service_Accounts	GRP-ServiceAccounts	Service Account

Service Account Controls: svc.financecore was created with Password Never Expires enabled, User Cannot Change Password enforced, and Account is Disabled until required by the application team. Interactive login is prohibited. This account is documented in the Service Account Register and reviewed quarterly.

8. Privilege Creep Detection & Remediation

8.1 Scenario

Alex Chen was promoted from Finance Analyst to Finance Manager 3 months prior to this review. The role change was partially processed — the Finance Manager group was added but the Finance Analyst group and InvoiceCreate permission were never removed. This resulted in accumulated permissions beyond the current job function, known as privilege creep.

8.2 Access Audit — Pre-Remediation

Username	GRP-Finance-Analysts	GRP-Finance-Managers	GRP-Finance-InvoiceCreate	GRP-Finance-InvoiceApprove	Privilege Creep?	SoD Conflict?
a.chen	**YES**	**YES**	**YES**	**YES**	**YES**	**YES — CRITICAL**
r.thompson	No	No	No	**YES**	No	No
m.obi	No	**YES**	No	**YES**	No	No

8.3 Formal Findings

ACCESS AUDIT FINDINGS
FINDING AF-001 — Privilege Creep
User: Alex Chen (a.chen) | Date: April 9, 2026

Description: User retains GRP-Finance-Analysts group membership despite promotion to Finance Manager 3 months ago. Old role was never removed during role change.
Risk: Excessive permissions beyond current job function. User can perform both Analyst and Manager operations simultaneously.
Rating: HIGH

FINDING AF-002 — SoD Violation (SOD-001)
User: Alex Chen (a.chen) | Date: April 9, 2026

Description: User is simultaneously a member of GRP-Finance-InvoiceCreate and GRP-Finance-InvoiceApprove, violating SoD policy SOD-001.
Risk: User can create and approve own invoices — enables financial fraud without detection. Regulatory breach: SOX Section 404.
Rating: CRITICAL

8.4 Remediation Actions

Action	Detail	Status
Remove from GRP-Finance-Analysts	Stale group from previous role — removed from Member Of tab	**REMEDIATED**
Remove from GRP-Finance-InvoiceCreate	Stale permission from previous role — removed from Member Of tab	**REMEDIATED**
Retain GRP-Finance-Managers	Current role — no change	Confirmed
Retain GRP-Finance-InvoiceApprove	Appropriate for Finance Manager — no change	Confirmed

Action	Detail	Status
Update provisioning log	Role change history documented with remediation date	**REMEDIATED**

8.5 Access Audit — Post-Remediation

Username	GRP-Finance-Analysts	GRP-Finance-Managers	GRP-Finance-InvoiceCreate	GRP-Finance-InvoiceApprove	Privilege Creep?	SoD Conflict?
a.chen	No	**YES**	No	**YES**	No	No — Resolved
r.thompson	No	No	No	**YES**	No	No
m.obi	No	**YES**	No	**YES**	No	No

9. Role Change Processing — CHG-0001

A formal role change request was received, approved, and processed following the standard IAM change control procedure. The change was executed as a clean swap — the old role was removed before the new role was assigned.

```
CHANGE TICKET: CHG-0001
Type: Role Change
Requested by: Sarah Johnson (HR Manager)
Approved by: James Carter (IT Director)

User: David Osei (d.osei)
Current Role: IT-Support
New Role: IT-Manager
Reason: Promoted following Karen Nwosu departure

Access Changes:
  REMOVE: GRP-IT-Support
  ADD:    GRP-IT-Managers
  ADD:    GRP-IT-Admins

Executed by: Opeyemi Ogundimu (IAM Analyst)
```

Step	Action	Old State	New State	Status
1	Remove GRP-IT-Support	Member	Removed	**REMEDIATED**
2	Add GRP-IT-Managers	Not member	Member	**REMEDIATED**
3	Add GRP-IT-Admins	Not member	Member	**REMEDIATED**
4	Update provisioning log	Not logged	Logged	**REMEDIATED**
5	Verify no stale access	N/A	Confirmed	**REMEDIATED**

> Clean Swap Principle: Every role change must remove the old role before assigning the new one. Adding only the new role without removing the old one creates privilege creep. This was enforced in CHG-0001 — GRP-IT-Support was removed in the same change window as the new groups were added.

10. Q1 Access Certification

A quarterly access certification was conducted across all FictionalCorp accounts. This review certifies that current access assignments are appropriate, up to date, and compliant with the role matrix and SoD policy.

Username	Full Name	Department	Current Groups	Decision	Reason
m.williams	Marcus Williams	Sales	GRP-Sales-Reps	Certify ✓	Active Sales Rep — access appropriate
j.park.contractor	Jessica Park	IT	GRP-IT-Contractors	Certify ✓	Contract active — verify expiry date
a.chen	Alex Chen	Finance	GRP-Finance-Managers, GRP-Finance-InvoiceApprove	Certify ✓	Post-remediation — privilege creep resolved
d.osei	David Osei	IT	GRP-IT-Managers, GRP-IT-Admins	Certify ✓	Post role change CHG-0001 — correct
r.thompson	Rachel Thompson	Finance	GRP-Finance-Approvers, GRP-Finance-InvoiceApprove	Certify ✓	Active Finance Approver — access appropriate
m.obi	Michael Obi	Finance	GRP-Finance-Managers, GRP-Finance-InvoiceApprove	Certify ✓	Finance Manager — access appropriate
svc.financecore	FinanceCore App	N/A	GRP-ServiceAccounts	Certify ✓	Service account — app-to-app only, no human login

```
Q1 ACCESS CERTIFICATION SUMMARY
Certification Period: Q1 2026
Completed by: Opeyemi Ogundimu — IAM Analyst
Date: April 9, 2026

Total accounts reviewed:        11
Certifications approved:        11
Access rights removed:           3  (privilege creep remediation — a.chen)
SoD violations found:            1  (AF-002 — remediated same day)
Open findings at close:          0
Next review due:                 90 days from today
```

11. Portfolio Screenshots

The following screenshots were captured as evidence of the completed lab and are stored in the Lab02_Portfolio folder on GitHub.

#	Screenshot File	What It Shows	Relevance
1	Role Matrix — Full View	Complete role matrix with colour coding (Allow/Deny/Read-Only), risk classifications, and document header	Primary RBAC governance evidence
2	SoD Policy Sheet	SoD policy document with 3 conflicting role pairs, risk ratings, and regulatory references	Compliance documentation
3	Alex Chen — Before Remediation	Member Of tab showing all 4 groups — privilege creep and SoD violation visible	Audit finding evidence
4	Alex Chen — After Remediation	Member Of tab showing correct 2 groups only	Remediation proof
5	Access Audit Report	Formal finding AF-001 and AF-002 with remediation status	Incident documentation
6	David Osei — Post Role Change	Member Of tab showing GRP-IT-Managers and GRP-IT-Admins after CHG-0001	Role change evidence
7	AD Group Structure	Finance and IT OUs expanded showing all 14 security groups	AD implementation proof
8	Q1 Certification Summary	Completed certification report showing 11 accounts reviewed, 0 open findings	Compliance audit artifact

12. Key Design Decisions & Rationale

Why build the role inventory before creating groups in AD?

Creating groups before designing the role model results in an ad-hoc access structure that is difficult to audit and maintain. Building the role inventory first ensures every group in AD has a documented purpose, a mapped job function, and a clear owner. This is the professional approach that scales.

Why does Finance-Manager have Invoice Approve but not Invoice Create?

Finance Managers need to oversee and approve invoice transactions but should not be creating them — that is the Finance Analyst function. Allowing a manager to create invoices they then approve removes the check-and-balance that SoD is designed to enforce. The only exception documented is where a Finance Manager approves in the absence of a dedicated approver, which requires CISO sign-off.

Why create a dedicated Service_Accounts OU?

Mixing service accounts into departmental OUs creates audit confusion and makes it difficult to apply distinct Group Policies to non-human accounts. A dedicated OU with its own security baseline — no interactive login, password never expires, disabled by default until required — is a security best practice and makes service account governance straightforward.

Why process role changes as a clean swap?

The most common cause of privilege creep is role changes where only the new access is added without removing the old. Every role change ticket must include both REMOVE and ADD actions. Processing them simultaneously in the same change window eliminates the window of excessive access and ensures the provisioning log reflects the user's actual current state.

13. Azure Connection — What Comes Next

AZURE ENTRA ID — LAB 05 PREVIEW

Every security group created in this lab will be synchronized to Microsoft Entra ID in Lab 05 via Azure AD Connect. In Entra ID, these groups become the targets for Conditional Access policy assignment — for example:

- GRP-IT-Admins will be targeted by a CA policy requiring PIM activation before any admin action
- GRP-Finance-Users will be targeted by a CA policy requiring MFA for FinanceCore access
- GRP-IT-Contractors will be restricted by a location-based CA policy

The role matrix built in this lab becomes the blueprint for the entire hybrid identity model.

14. Interview Stories

INTERVIEW STORY 1

Q: How do you approach role design?

A: Before building anything in the system, I design a role matrix — a document that maps every job title to its permitted systems and resources. I use it to enforce least privilege and to identify SoD conflicts before they get built into the environment. In my lab I caught a Finance user who had both invoice creation
and approval rights — a critical SoD violation that would allow someone to authorize their own payments. I documented it as a formal finding, remediated it, and updated the certification log. The role matrix becomes the single source of truth that auditors reference during every access review.

INTERVIEW STORY 2

Q: What is privilege creep and how do you handle it?

A: Privilege creep happens when users accumulate permissions over time — usually through role changes
where old access is never cleaned up. In my lab I simulated a Finance Analyst promoted to Finance Manager
who retained all their old group memberships. I detected it during a quarterly access audit, raised a formal finding with a risk rating, remediated it by removing the stale groups, and updated the provisioning log with the full remediation history. The fix for privilege creep at scale is a quarterly access certification cycle — which I also ran and documented in this lab.

15. Portfolio Deliverables

Deliverable	Format	GitHub Location	Status
RBAC Role Inventory	Excel sheet	/Lab02-RBAC-Role-Matrix/	Complete ✓
Role Matrix v1.0	Excel sheet	/Lab02-RBAC-Role-Matrix/	Complete ✓
SoD Policy Document	Excel sheet	/Lab02-RBAC-Role-Matrix/	Complete ✓
Access Audit Report (AF-001/002)	Excel sheet	/Lab02-RBAC-Role-Matrix/	Complete ✓
Q1 Access Certification	Excel sheet	/Lab02-RBAC-Role-Matrix/	Complete ✓
Provisioning Log (updated)	Excel (.xlsx)	/Docs/	Complete ✓
Lab 02 Screenshots (x8)	PNG	/Lab02-RBAC-Role-Matrix/Screenshots/	Complete ✓
Lab 02 Documentation	Word (.docx)	/Lab02-RBAC-Role-Matrix/	Complete ✓

16. Next: Lab 03

NEXT LAB
Lab 03 — Employee Offboarding & Access Revocation

Lab 03 covers the most time-sensitive and highest-risk IAM task — termination processing.
A missed offboarding step is one of the most common audit findings and the #1 insider threat vector.
The lab simulates a real termination ticket arriving at end of day, executes the full hybrid offboarding procedure across AD and Entra ID, and produces a production-ready offboarding checklist as the portfolio deliverable.

Document prepared by: Opeyemi Ogundimu

GitHub: github.com/okpe027/My_First_Project

Part of the 10-Week Hybrid IAM Analyst Lab Program